# Chat Application Server - Hướng dẫn triển khai

## Mô tả

Hệ thống Chat Server được xây dựng với .NET 6 và Oracle Database, hỗ trợ các tính năng:

- **Xác thực và bảo mật**: Đăng ký, đăng nhập, OTP qua email, quên mật khẩu
- **MAC (Mandatory Access Control)**: Kiểm soát truy cập dựa trên mức clearance và security label
- **VPD (Virtual Private Database)**: Tự động lọc dữ liệu theo clearance level
- **Quản lý cuộc trò chuyện**: Tạo/xóa nhóm, chat riêng tư, quản lý thành viên
- **Phân quyền chi tiết**: Owner, Admin, Member với các quyền khác nhau
- **Ban/Mute**: Cấm hoặc tắt tiếng thành viên
- **Audit logging**: Ghi log tất cả hành động nhạy cảm
- **Mã hóa**: AES cho kênh truyền TCP

## Yêu cầu hệ thống

- .NET 6 SDK trở lên
- Oracle Database 11g trở lên (đã test với Oracle XE)
- Oracle.ManagedDataAccess.Core NuGet package
- Microsoft.Extensions.Configuration (cho appsettings.json)

## Cài đặt

### 1. Chuẩn bị Database

```sql
-- Đăng nhập với quyền DBA
sqlplus sys/password@localhost:1521/XE as sysdba

-- Chạy schema.sql để tạo user và tables
@schema.sql

-- Chạy seeds.sql để thêm dữ liệu mẫu
@seeds.sql
```

### 2. Cấu hình Server

Chỉnh sửa `appsettings.json`:

```json
{
  "EmailSettings": {
    "SmtpHost": "smtp.gmail.com",
    "SmtpPort": 587,
    "SmtpUsername": "your-email@gmail.com",
    "SmtpPassword": "your-app-password",
    "FromEmail": "your-email@gmail.com",
    "FromName": "Chat Application"
  },
  "Database": {
    "ConnectionString": "User Id=ChatNoiBo_DoAn1;Password=123;Data Source=localhost:1521/XE"
  },
  "Server": {
    "Port": 9000
  }
}
```

**Lưu ý về Email**:

- Nếu dùng Gmail, cần tạo App Password (không dùng mật khẩu chính)
- Nếu không cấu hình email, OTP sẽ được in ra console (chế độ demo)

### 3. Biên dịch và chạy

```bash
# Restore packages
dotnet restore

# Build
dotnet build

# Run
dotnet run
```

Server sẽ lắng nghe trên port 9000 (hoặc port cấu hình trong appsettings.json).

## Kiến trúc hệ thống

```
┌──────────────────────┐
│   TCP Client    │
│  (Encrypted)    │
└──────────┬──────────┘
           │
```

```
    ▼
┌──────────────────────────────────────┐
│  SocketServerService                 │
│  - Accept connections                │
│  - Encrypt/Decrypt (AES)             │
└──────────────────────────────────────┘
    │
    ▼
┌──────────────────────────────────────┐
│  ChatProcessingService               │
│  - Parse requests                    │
│  - Business logic                    │
│  - MAC enforcement                   │
└──────────────────────────────────────┘
    │
    ▼
┌──────────────────────────────────────┐
│  DbContext                           │
│  - Oracle connection                 │
│  - Execute queries/procedures        │
│  - Set VPD context                   │
└──────────────────────────────────────┘
    │
    ▼
┌──────────────────────────────────────┐
│  Oracle Database                     │
│  - Tables                            │
│  - VPD Policies                      │
│  - Triggers                          │
│  - Stored Procedures                 │
└──────────────────────────────────────┘
```

## Protocol API

Client gửi JSON được mã hóa AES qua TCP. Format:

```json
{
  "Action": "ActionName",
  "SenderUsername": "user123",
  "ClearanceLevel": 2,
  "SecurityLabel": 2,
  // ... các field khác tùy action
}
```

**Actions không cần authentication:**

### Login

```json
{
  "Action": "Login",
  "SenderUsername": "user123",
  "Password": "password123"
}
```

### Register

```json
{
  "Action": "Register",
  "SenderUsername": "newuser",
  "Password": "password123",
  "Email": "user@example.com",
  "ClearanceLevel": 1
}
```

### VerifyOtp

```json
{
  "Action": "VerifyOtp",
  "SenderUsername": "newuser",
  "Otp": "123456"
}
```

### ForgotPasswordRequest

```json
{
  "Action": "ForgotPasswordRequest",
  "SenderUsername": "user123",
  "Email": "user@example.com"
}
```

### ResetPassword

```json
```

```
{
  "Action": "ResetPassword",
  "SenderUsername": "user123",
  "Otp": "123456",
  "NewPassword": "newpassword123"
}
```

**Actions cần authentication:**

**CreateConversation**

```json
{
  "Action": "CreateConversation",
  "SenderUsername": "user123",
  "ClearanceLevel": 2,
  "ConversationName": "Project Team",
  "IsPrivateConversation": false
}
```

**GetConversations**

```json
{
  "Action": "GetConversations",
  "SenderUsername": "user123",
  "ClearanceLevel": 2
}
```

**GetConversationMessages**

```json
{
  "Action": "GetConversationMessages",
  "SenderUsername": "user123",
  "ClearanceLevel": 2,
  "ConversationId": "CTC_0001"
}
```

**SendMessage**

```json
```

```
{
  "Action": "SendMessage",
  "SenderUsername": "user123",
  "ClearanceLevel": 2,
  "ConversationId": "CTC_0001",
  "Content": "Hello team!",
  "SecurityLabel": 2
}
```

### AddMember

```json
{
  "Action": "AddMember",
  "SenderUsername": "admin",
  "ClearanceLevel": 2,
  "ConversationId": "CTC_0001",
  "TargetUsername": "newmember"
}
```

### RemoveMember

```json
{
  "Action": "RemoveMember",
  "SenderUsername": "admin",
  "ClearanceLevel": 2,
  "ConversationId": "CTC_0001",
  "TargetUsername": "oldmember"
}
```

### BanMember / UnbanMember

```json
{
  "Action": "BanMember",
  "SenderUsername": "admin",
  "ClearanceLevel": 2,
  "ConversationId": "CTC_0001",
  "TargetUsername": "baduser"
}
```

### MuteMember / UnmuteMember

```json
{
  "Action": "MuteMember",
  "SenderUsername": "admin",
  "ClearanceLevel": 2,
  "ConversationId": "CTC_0001",
  "TargetUsername": "spammer"
}
```

**DeleteConversation**

```json
{
  "Action": "DeleteConversation",
  "SenderUsername": "owner",
  "ClearanceLevel": 2,
  "ConversationId": "CTC_0001"
}
```

**Server Response:**

```json
{
  "Success": true,
  "Message": "Operation successful",
  "ClearanceLevel": 2,
  "ConversationId": "CTC_0001",
  "MessageId": 12345,
  "Messages": [...],
  "Conversations": [...]
}
```

## MAC (Mandatory Access Control)

**Clearance Levels:**

- **1**: LOW - Người dùng thông thường
- **2**: MEDIUM - Quản lý cấp trung
- **3**: HIGH - Quản trị viên, lãnh đạo

**Security Labels:**

- **1**: PUBLIC - Thông tin công khai

- **2**: CONFIDENTIAL - Thông tin nội bộ
- **3**: SECRET - Thông tin bí mật

**Quy tắc:**

1. **No Read Up**: User chỉ đọc được tin nhắn có label ≤ clearance của mình
   - User với clearance=1 chỉ đọc được label=1
   - User với clearance=2 đọc được label=1,2
   - User với clearance=3 đọc được tất cả
2. **No Write Down**: User không được ghi tin nhắn có label < clearance
   - User với clearance=3 không được ghi tin label=1 hoặc 2
   - User với clearance=2 không được ghi tin label=1
   - Điều này ngăn thông tin bị rò rỉ xuống mức thấp hơn

**VPD (Virtual Private Database):**

Oracle VPD tự động thêm điều kiện `WHERE SECURITYLABEL <= user_clearance` vào mọi query SELECT trên bảng TINNHAN. Context được set qua:

```csharp
await dbContext.SetSessionUserLevelAsync(username, clearanceLevel);
```

## Phân quyền trong Conversations

**Roles:**

- **OWNER**: Chủ nhóm - toàn quyền
- **ADMIN**: Quản trị viên - hầu hết quyền trừ xóa nhóm
- **MEMBER**: Thành viên - chỉ xem và chat

**Permissions:**

- `CAN_ADD`: Thêm thành viên
- `CAN_REMOVE`: Xóa thành viên
- `CAN_DELETE`: Xóa conversation
- `CAN_BAN`: Ban thành viên
- `CAN_UNBAN`: Unban thành viên
- `CAN_MUTE`: Mute thành viên
- `CAN_UNMUTE`: Unmute thành viên

## Audit Logging

Tất cả hành động quan trọng được ghi vào bảng `AUDIT_LOGS`:

- LOGIN_SUCCESS / LOGIN_FAILED
- REGISTER
- SEND_MESSAGE
- CREATE_CONVERSATION
- ADD_MEMBER / REMOVE_MEMBER
- BAN_MEMBER / UNBAN_MEMBER
- MUTE_MEMBER / UNMUTE_MEMBER
- DELETE_CONVERSATION

## Testing

**Tài khoản mẫu (từ seeds.sql):**

| Username | Password | Clearance | Role |
|---|---|---|---|
| TK001 | 2313131 | 3 | Owner |
| TK002 | 27577451 | 2 | Admin |
| TK003 | 23175437 | 1 | User |
| TK004 | 23174745 | 1 | User |
| TK005 | 23046906 | 1 | User |

**Flow test cơ bản:**

1. **Login**: TK001 (clearance=3)
2. **Create Conversation**: Tạo nhóm "Test Team"
3. **Add Member**: Thêm TK003 vào nhóm
4. **Send Message**: Gửi tin với label=3
5. **Login as TK003**: (clearance=1)
6. **Get Messages**: Không thấy tin label=3 (MAC enforcement)

## Bảo mật

**Implemented:**

- ✅ Password hashing (SHA256)
- ✅ OTP verification

- ✅ AES encryption cho TCP channel
- ✅ MAC enforcement (application + database level)
- ✅ VPD policies
- ✅ Audit logging
- ✅ Ban/Mute functionality
- ✅ Permission-based actions

**Recommendations cho Production:**

- Sử dụng bcrypt/Argon2 thay vì SHA256 cho password
- Implement token-based authentication (JWT)
- Thêm rate limiting
- SSL/TLS cho TCP connection
- Mã hóa dữ liệu nhạy cảm trong database
- Implement session management
- Add CAPTCHA cho login

## Troubleshooting

**Connection refused:**

- Kiểm tra Oracle listener đang chạy: `lsnrctl status`
- Kiểm tra connection string trong appsettings.json

**OTP không gửi được:**

- Nếu dùng Gmail, tạo App Password tại: https://myaccount.google.com/apppasswords
- Kiểm tra SMTP settings
- Nếu không config email, check console output

**MAC policy không hoạt động:**

- Kiểm tra context đã được set: `SELECT SYS_CONTEXT('MAC_CTX', 'USER_LEVEL') FROM DUAL;`
- Verify VPD policy: `SELECT * FROM DBA_POLICIES WHERE OBJECT_NAME = 'TINNHAN';`

**Permission denied:**

- Kiểm tra role của user trong conversation
- Verify PHAN_QUYEN_NHOM settings

## Mở rộng

**Thêm features:**

1. File attachments (đã có table ATTACHMENT)
2. Video/voice calls
3. Message reactions
4. Read receipts
5. Push notifications
6. Message search
7. User profiles

**Tối ưu performance:**

1. Connection pooling
2. Caching (Redis)
3. Message pagination
4. Lazy loading
5. Database indexing

## License

Educational project - Do An 1

## Contributors

- Development Team
- Database Team
- Security Team